

# Information Governance and Data Handling Policy

Document NGS-POL-004 • Version 2.1 • Approved by the Board on 18 November 2025 • Next scheduled review November 2027

## 1. Purpose and Scope

- 1.1 This Policy governs how Northgate Systems Limited ("the Company") collects, processes, stores, transfers and disposes of personal data and other regulated information.
- 1.2 It applies to all employees, contractors, interns and third-party processors acting on the Company's instruction.
- 1.3 The Company is an enterprise software business incorporated in Nigeria in 2024. Its principal products are a behavioural risk-scoring platform sold to banks and a spend-control platform sold to corporate finance teams.

## 2. Company Profile and Processing Footprint

- 2.1 As at 30 June 2026 the Company processed personal data relating to approximately **640,000 distinct data subjects** in the preceding six-month period, of whom substantially all were end customers of the Company's bank clients.
- 2.2 The behavioural risk-scoring platform derives device interaction patterns, transaction sequencing and location traces, and produces a numeric risk score used by client banks to accept, challenge or decline a transaction.
- 2.3 In the financial year ended 31 December 2026 the Company projects gross turnover of **NGN 96,000,000** and total fixed assets of **NGN 265,000,000**. Approximately 62 per cent of turnover is derived from software subscription licences and 38 per cent from implementation and advisory engagements.
- 2.4 The Company has not registered with the National Data Governance Commission and has not to date filed a Compliance Audit Return.

## 3. Lawful Basis and Consent

- 3.1 The Company processes personal data on the lawful bases of contract performance, legitimate interest in fraud prevention, and consent where no other basis applies.
- 3.2 Consent, where relied upon, is captured through a timestamped record in the platform consent ledger, together with the version of the notice presented.
- 3.3 The legitimate interest basis relied upon for fraud prevention has been documented in a balancing assessment maintained by the Legal team.

## 4. Security Controls

- 4.1 Personal data is encrypted in transit using TLS 1.3 and at rest using AES-256.
- 4.2 Access to production systems is granted on a least-privilege basis through role-based access control, reviewed quarterly by the Head of Engineering.
- 4.3 Multi-factor authentication is mandatory for all production access.

4.4 All staff complete information security and data protection training on joining and annually thereafter. Completion is tracked by People Operations.

4.5 Penetration testing is commissioned annually from an external provider.

## 5. Breach Management

5.1 A breach register is maintained by the Security team and records every suspected or confirmed incident, whether or not it is externally notifiable.

5.2 Where an incident is assessed as a reportable personal data breach, the Company will notify the relevant regulator **within 72 hours** of the Security team confirming the incident.

5.3 Affected individuals will be notified where the Company assesses that there is a high risk to their rights, within a reasonable period following regulator notification.

5.4 The Company's processor agreements require sub-processors to notify the Company of an incident within 72 hours.

## 6. Data Protection Officer

6.1 The Chief Technology Officer is designated as the Company's Data Protection Officer.

6.2 The Chief Technology Officer also holds operational responsibility for platform architecture, production security and system availability.

6.3 The Data Protection Officer reports to the Chief Executive Officer and presents a summary of privacy matters to the Board twice yearly.

6.4 The Company has not yet enrolled the Data Protection Officer in an accredited data protection certification programme; this is scheduled for the 2027 training cycle.

## 7. Impact Assessments

7.1 The Company carries out a security design review before releasing a major new feature. The review covers threat modelling, authentication and data flow.

7.2 A formal data protection impact assessment has not been carried out in respect of the behavioural risk-scoring platform. The Company's position is that the platform produces an advisory score and that the final accept or decline decision rests with the client bank.

7.3 Where a client bank requests an impact assessment as part of its own vendor onboarding, the Company completes the client's questionnaire. No independent assessment is retained by the Company.

## 8. Cross-Border Transfers and Sub-Processors

8.1 Production workloads are hosted with a cloud provider in the United States (us-east-1) with a disaster recovery region in Ireland.

8.2 Analytics and model training are carried out on infrastructure located in Ireland.

8.3 The Company relies on the consent obtained under paragraph 3.2, together with the transfer clauses in its master services agreements, as the basis for these transfers.

8.4 No transfer impact assessment has been prepared. No transfer instrument has been submitted to a regulator for approval.

8.5 A register of sub-processors is maintained and published on the Company's trust page.

## 9. Data Subject Requests

9.1 Requests from individuals to access, correct or delete their personal data are routed to [privacy@northgatesystems.example](mailto:privacy@northgatesystems.example).

9.2 The Company aims to acknowledge a request within 5 working days and to complete it **within 45 days** of receipt.

9.3 Where the individual is a customer of a client bank, the Company will refer the request to the client bank and take no further action unless instructed.

9.4 A fee of NGN 5,000 may be charged where a request is assessed as manifestly repetitive.

## 10. Retention and Disposal

10.1 Retention periods are set out in Table 1.

**Table 1 - Retention schedule**

| Record class                             | Retention period                                 | Disposal method                  |
|------------------------------------------|--------------------------------------------------|----------------------------------|
| System access and authentication logs    | 24 months                                        | Automatic expiry in log platform |
| Behavioural risk scores and model inputs | 36 months                                        | Cryptographic erasure            |
| Consent records                          | Life of the customer relationship plus 24 months | Soft delete then purge           |
| Breach register entries                  | 36 months                                        | Archive then delete              |
| Books of account, invoices and contracts | 3 years                                          | Secure destruction               |
| Employee records                         | 6 years after termination                        | Secure destruction               |

10.2 Retention periods are reviewed when the Policy is reviewed.

## 11. Records of Processing

11.1 A record of processing activities is maintained in a shared spreadsheet by the Legal team.

11.2 The record was last updated in March 2025 and is reviewed on an ad hoc basis when a new processing activity is introduced.

## 12. Regulatory Filings

12.1 Where filings are required, the Company intends to prepare and submit them directly using internal resources rather than through an external compliance organisation.

12.2 The Company files its annual tax return within six months of its financial year end and holds a Taxpayer Identification Number.

12.3 The Company treats itself as a small company for tax purposes on the basis that its turnover is below NGN 100,000,000.

## 13. Governance and Review

13.1 This Policy is owned by the Chief Technology Officer and approved by the Board.

13.2 The Policy is reviewed every 24 months, or sooner where a material regulatory change occurs.

13.3 Breach of this Policy by an employee may result in disciplinary action.

**Version history.** v1.0 (March 2024) initial issue. v2.0 (February 2025) added sub-processor register and quarterly access review. v2.1 (November 2025) updated retention schedule and breach notification timing.